

Assignment #2 - Segurança e Privacidade

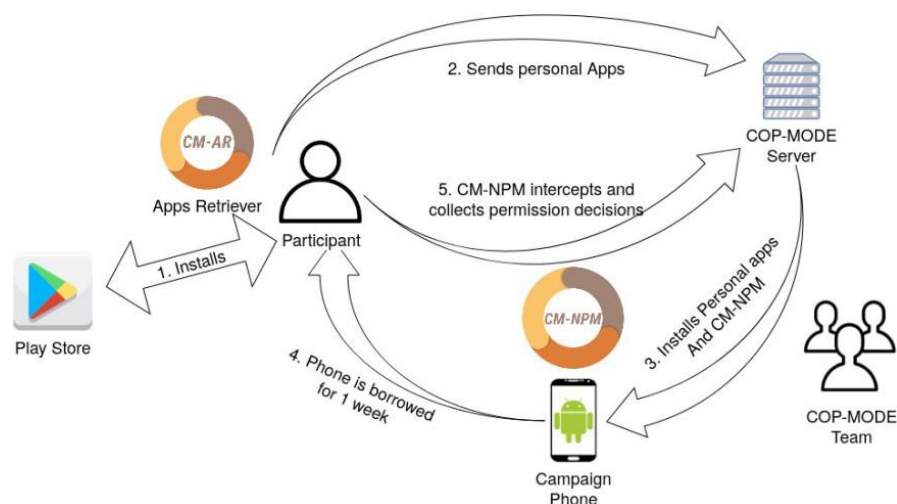
Realizado por Guilherme Kotchergenko 201910641, Hugo Melo 202304068 e Isabela Cartaxo 202300339

1. Privacy Threshold Analysis (PTA)

Descrição do sistema

O COP-MODE é um sistema académico que estuda como os utilizadores lidam com pedidos de permissões em smartphones, tendo em conta o contexto. Os participantes utilizam, durante cerca de uma semana, um telemóvel fornecido pela equipa, onde são instaladas as suas aplicações pessoais e o gestor CM-NPM. Este gestor regista os pedidos de permissões em tempo real, juntamente com informação sobre o estado do dispositivo e localização. Os dados são recolhidos de forma contínua e armazenados para análise em servidores da instituição promotora, sob salvaguardas técnicas e organizacionais.

Figura 1: COP-MODE Campaigns Methodology



Dados pessoais recolhidos

Durante a campanha, são recolhidos diferentes tipos de dados, alguns diretamente identificáveis e outros contextuais.

Figura 2: COP-MODE Summary of Main Data Collected. Dados sensíveis identificados com *

Type of Collection	Data
At beginning	Email address
Snapshot	* Installed Apps and respective permission settings
	Connection Type (wi-fi, cellular, other)
	Device context (idle, in use, in call, etc)
	* Calendar entries (calendar identifier, location and start and end dates)
Continuous	* Geographic Location (latitude, longitude, altitude)
	* Devices nearby (Bluetooth MAC address + WiFi BSSIDs)
At Permission Prompt	Application info (*name, version, category, visibility)
	User decision
	Semantic Location (user input)

Origem dos dados

Todos os dados são recolhidos diretamente dos dispositivos fornecidos aos participantes. Estes dispositivos são configurados pela entidade promotora do COP-MODE, e os dados são recolhidos com base no consentimento informado prestado pelo utilizador antes da ativação do sistema.

Com base na análise acima, e tendo em conta a natureza sensível e identificável da maioria destes dados, especialmente localização contínua e contactos indiretos (e.g., dispositivos próximos), determina-se que o sistema justifica plenamente a realização de uma Avaliação de Impacto sobre a Privacidade (PIA).

2. Preparação do PIA

Antes de iniciar formalmente a Avaliação de Impacto sobre a Privacidade (PIA), foi realizada uma fase de preparação com os seguintes elementos essenciais.

Definição do *scope* e critérios de risco

O PIA abrange todas as fases do sistema COP-MODE, desde a recolha de dados no smartphone até à sua eliminação. Para avaliar os riscos, definimos dois critérios simples: quão grave seria o impacto no participante e qual a probabilidade de isso acontecer. Cada risco foi classificado numa escala de 1 (negligenciável) a 4 (máximo).

Identificação dos stakeholders

Os principais intervenientes identificados como potencialmente afetados ou envolvidos foram:

- Os participantes voluntários da campanha (titulares dos dados)
- A equipa técnica responsável pela configuração e manutenção dos smartphones
- Os investigadores com acesso aos dados para análise
- A instituição promotora do projeto (como controladora e processadora dos dados)
- Potenciais parceiros externos interessados nos dados anonimizados (terceiros)

3. Identificação dos fluxos de informação (PII Flows)

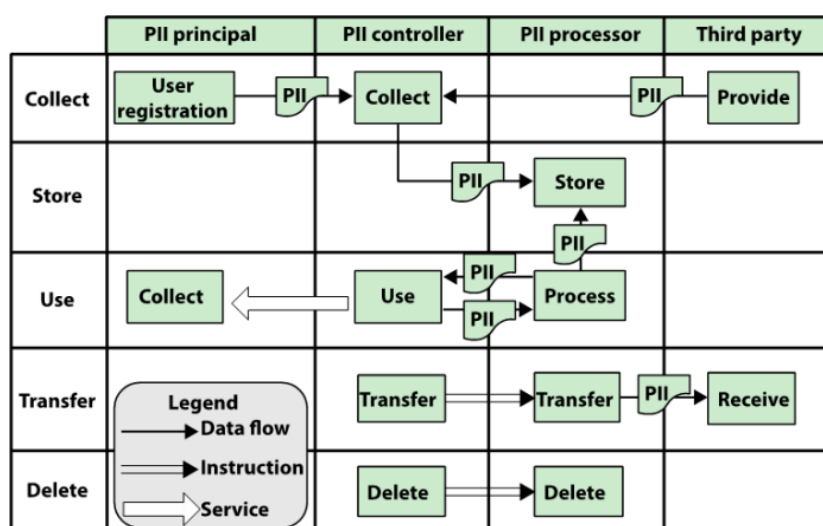
Entidades envolvidas

- **PII Principals:** Participantes voluntários do COP-MODE. Podem ser identificados diretamente (ex: email) ou indiretamente (ex: localização, apps instaladas).
- **PII Controller:** Entidade promotora do projeto, que define finalidades e meios do tratamento.
- **PII Processor:** Pode ser a mesma entidade, desde que execute o tratamento sob instruções do controlador.
- **Third parties:** Entidades externas que poderão ter acesso apenas a dados anonimizados, sem identificadores diretos.

Descrição do fluxo de dados

1. **Recolha:** os dados são recolhidos automaticamente pela aplicação COP-MODE instalada nos smartphones fornecidos aos participantes. Esta recolha é contínua e inclui localização, apps instaladas, calendário, entre outros.
2. **Transmissão:** os dados são enviados do smartphone para o servidor COP-MODE através de ligação à internet (Wi-Fi ou dados móveis).
3. **Armazenamento:** os dados são guardados num servidor central, sob responsabilidade da instituição promotora. Os identificadores (como o email) são guardados separadamente para efeitos de pseudonimização.
4. **Acesso:** investigadores autorizados podem aceder aos dados pseudonimizados para análise científica. Não têm acesso direto aos identificadores.
5. **Transferência:** Dados tratados e anonimizados podem ser partilhados com parceiros académicos externos.
6. **Eliminação:** após o fim do período de retenção (máximo 12 meses), os dados são eliminados ou anonimizados de forma permanente.

Figura 3: Workflow Diagram of PII Processing



O COP-MODE recolhe dados de forma automática e contínua, por exemplo através da localização e das permissões concedidas pelo utilizador. Os participantes são os principais afetados, sendo registado o seu comportamento digital ao longo da campanha.

Os dados são tratados para fins de investigação científica em servidores da instituição promotora, com acesso restrito. Aplicam-se políticas internas de separação de dados identificáveis e pseudonimizados, em conformidade com os princípios definidos no RGPD.

No conjunto, a estrutura do fluxo de dados exige cuidados técnicos e organizacionais robustos, que serão analisados nos tópicos seguintes.

4. Avaliação de riscos — configuração base (plain setup)

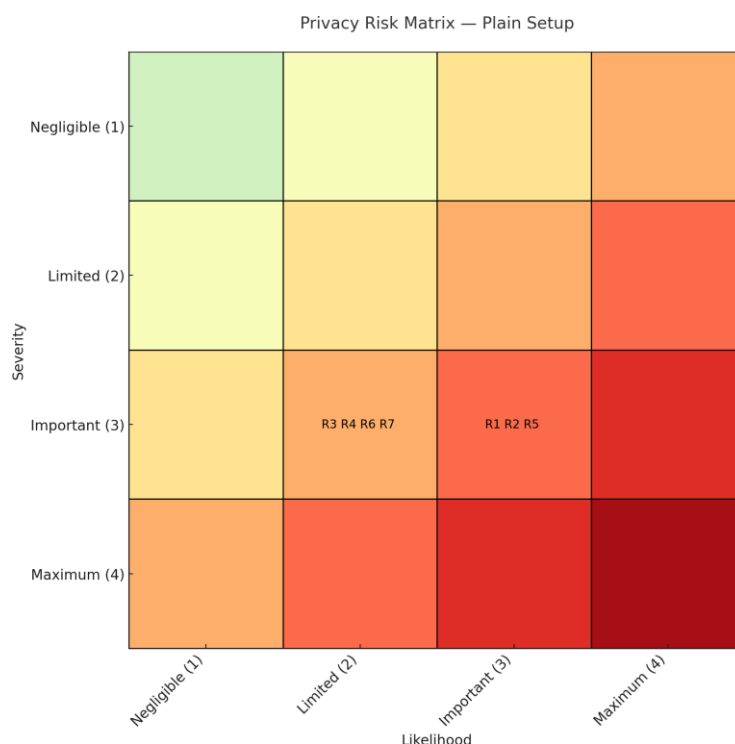
Nesta fase é feita uma avaliação dos riscos do sistema COP-MODE assumindo uma configuração sem qualquer proteção técnica ou organizacional, tal como recomendado na bibliografia anexada. A classificação segue os critérios definidos na ferramenta fornecida [3] e representados na interface da CNIL:

- **Likelihood (Probabilidade):** Quão provável é que o risco ocorra. Escala:
 - Negligenciável (1)
 - Limitado (2)
 - Importante (3)
 - Máximo (4)
- **Severity (Gravidade):** Impacto potencial sobre os titulares dos dados. Escala:
 - Negligenciável (1)
 - Limitado (2)
 - Importante (3)
 - Máximo (4)
- **Risk Level:** Produto da gravidade pela probabilidade. Classificação:
 - 1–3: Baixo
 - 4–6: Médio
 - 7–9: Elevado
 - 10–16: Crítico

Avaliação de riscos (Plain Setup)

#	Risco	Gravidade	Probabilidade	Nível de Risco	Classificação
R1	Eavesdropping nas comunicações	Importante (3)	Importante (3)	9	Elevado
R2	Acesso não autorizado ao servidor/dados	Importante (3)	Importante (3)	9	Elevado
R3	Ligação de dados em repouso (email visível)	Importante (3)	Limitado (2)	6	Médio
R4	Fuga de nomes de aplicações sensíveis	Importante (3)	Limitado (2)	6	Médio
R5	Acesso ilegítimo a todos os dados	Importante (3)	Importante (3)	9	Elevado
R6	Modificação não autorizada dos dados	Importante (3)	Limitado (2)	6	Médio
R7	Perda ou desaparecimento de dados	Importante (3)	Limitado (2)	6	Médio

Figura 4: Matriz de Risco, da ferramenta CNIL PIA



5. Plano de ação e mitigação

Após identificar os riscos associados ao sistema COP-MODE na sua configuração base, definimos um conjunto de mitigações destinadas a reduzir a probabilidade de ocorrência e/ou a gravidade dos seus impactos. Estas medidas baseiam-se em princípios fundamentais da segurança da informação, como confidencialidade, integridade, disponibilidade, minimização de dados e controlo de acessos, e refletem mecanismos discutidos ao longo da unidade curricular.

O objetivo destas medidas é:

- **Reduzir o nível de risco associado a cada cenário identificado** na matriz do tópico 4;
- **Introduzir proteções técnicas e organizacionais** que sejam proporcionais aos riscos;
- **Garantir conformidade com os princípios do RGPD**, como a pseudonimização, a limitação da finalidade e a responsabilização (accountability).

As medidas são apresentadas na tabela seguinte e serão posteriormente avaliadas no tópico 6, com a nova matriz de risco resultante da sua aplicação.

Mitigações por risco identificado

Risco	Mitigações
Eavesdropping nas comunicações	- Utilização de HTTPS/TLS para encriptação. - Validação de certificados digitais. - Bloqueio de transmissões inseguras por rede pública.
Acesso não autorizado ao servidor	- Autenticação forte (OAuth 2.0 / JWT). - Firewalls e VPNs. - RBAC (controlo de acesso baseado em funções). - Atualizações e correções regulares.
Ligação entre email e dados sensíveis	- Separação lógica de identificadores. - Pseudonimização e encriptação AES-256. - Bases de dados separadas com permissões distintas.
Fuga de nomes de aplicações	- Anonimização semântica dos nomes (ex: categorias). - Acesso restrito aos dados das apps. - Aplicação do princípio da minimização.
Acesso ilegítimo a dados recolhidos	- Revisão periódica de permissões. - Ativação de registos de auditoria. - Alertas de acesso anómalo.
Modificação não autorizada dos dados	- Verificação de integridade com funções hash. - Backups automáticos e versionamento. - Validação de inputs. - Logging de alterações.
Perda de dados	- Backups regulares e redundância. - Checksums nas transmissões. - Testes periódicos à integridade e à recuperação.

Estas medidas não só reduzem o nível absoluto de risco, como também reforçam a capacidade de resposta a incidentes, e demonstram um compromisso com a responsabilização (accountability) exigida pela legislação.

6. Reavaliação dos riscos após a mitigação

Com as mitigações aplicadas, realizámos uma nova avaliação através da ferramenta [3], comparando os riscos antes e depois. A matriz seguinte mostra que todos os riscos passaram a nível baixo, refletindo o impacto de medidas como encriptação, pseudonimização e controlo de acessos.

Comparação entre riscos iniciais e residuais

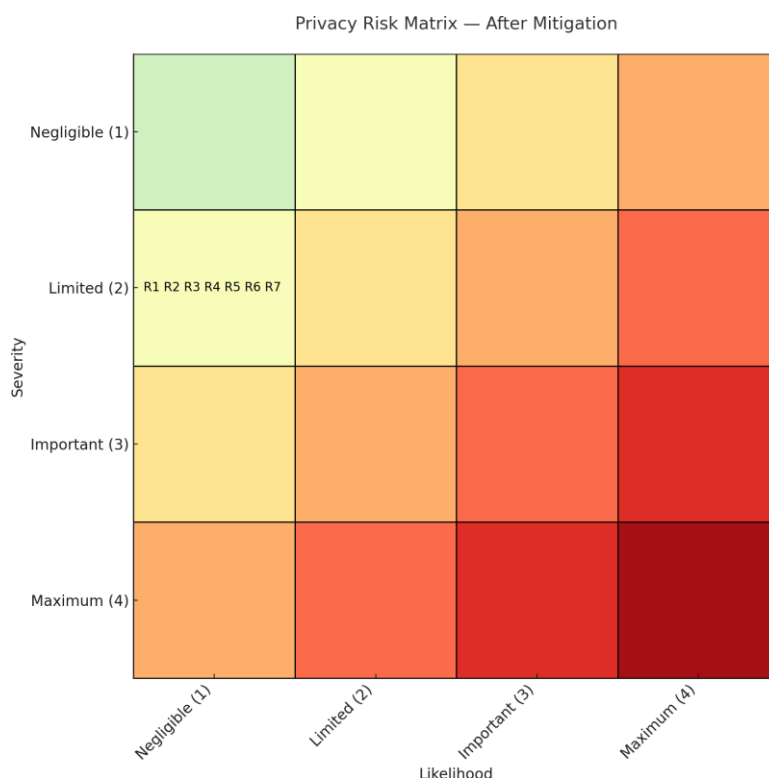
#	Risco	Risco Inicial	Risco Residual	Justificação
R1	Eavesdropping nas comunicações	Elevado (9)	Baixo (2)	TLS e validação de certificados tornam a interceção praticamente inviável. Dados cifrados não são legíveis se capturados.
R2	Acesso não autorizado ao servidor	Elevado (9)	Baixo (2)	Autenticação forte, firewall e RBAC reduzem significativamente a probabilidade e o impacto de intrusão.
R3	Ligação entre email e dados sensíveis	Médio (6)	Baixo (2)	Separação de identificadores e dados sensíveis impede reidentificação direta. Encriptação protege contra acesso não autorizado.

R4	Fuga de nomes de aplicações	Médio (6)	Baixo (2)	Categorização e controlo de acesso limitam o impacto da exposição e reduzem a probabilidade de fuga.
R5	Acesso ilegítimo a dados recolhidos	Elevado (9)	Baixo (2)	Privilégios mínimos, revisão de acessos e logging reduzem a probabilidade de abuso interno ou externo.
R6	Modificação não autorizada dos dados	Médio (6)	Baixo (2)	Validação de integridade, logging e backups permitem prevenir e reverter alterações maliciosas ou acidentais.
R7	Perda de dados	Médio (6)	Baixo (2)	Backups automáticos, redundância e verificação de integridade asseguram a disponibilidade e recuperação dos dados em caso de falha.

Representação visual

A nova matriz de risco (Figura 5) demonstra que todos os riscos foram deslocados para o quadrante superior esquerdo da matriz, indicando um nível de risco aceitável. Esta evolução valida a eficácia das mitigações propostas.

Figura 5: Matriz de risco após mitigação, da ferramenta CNIL PIA



7. Conclusão

A PIA permitiu identificar e avaliar riscos relevantes no sistema COP-MODE, inicialmente com níveis médios e elevados. Após aplicação de mitigações como encriptação, pseudonimização e controlo de acessos, todos os riscos foram reduzidos para níveis baixos. O sistema, tal como configurado, mostra-se adequado do ponto de vista da privacidade, desde que as salvaguardas sejam mantidas e revistas regularmente.

8. Uso de IA

Neste projeto não foram utilizadas ferramentas de inteligência artificial, aparte de pequenas pesquisas acerca dos conceitos que o integram.

9. Referências

[1] William Stallings, “Information Privacy Engineering and Privacy by Design”, Pearson Addison-Wesley, 2020

[2] Guidelines and software for PIA: <https://www.cnil.fr/en/privacy-impact-assessment-pia>

[3] CNIL PIA tool: <https://www.cnil.fr/en/open-source-pia-software-helps-carry-out-data-protection-impact-assessment>

[4] Statistics New Zealand, "Privacy Impact Assessment for the Integrated Data Infrastructure", 2012. [https://www. stats.govt.nz/assets/Uploads/Retirement-of-archive-website-project-files/Privacy-Impact-Assessment/Privacyimpact-assessment-for-the-Integrated-Data-Infrastructure/idi-privacy-impact-assessment.pdf](https://www.stats.govt.nz/assets/Uploads/Retirement-of-archive-website-project-files/Privacy-Impact-Assessment/Privacyimpact-assessment-for-the-Integrated-Data-Infrastructure/idi-privacy-impact-assessment.pdf)

[5] E.U. Smart Grid Task Force, "Data Protection Impact Assessment Template for Smart Grid and Smart Metering Systems", September 2018, https://energy.ec.europa.eu/system/files/2018-09/dpia_for_publication_2018_0.pdf